Практическое тестовое задание

Необходимо разработать одну или несколько сигнатур в синтаксисе Suricata для обнаружения сетевых соединений между агентом Medusa фреймворка Mythic C2 и управляющим сервером Mythic при использовании HTTP-транспорта (HTTP C2 Profile).

Иными словами, необходимо самостоятельно развернуть Mythic C2 и агент Medusa, установить соединение агента с управляющим сервером через HTTP C2 Profile, сгенерировать сетевые сессии с как можно более разнообразной активностью агента, записать полученный сетевой трафик и разработать Suricata-сигнатуры для его обнаружения.

Разработанные сигнатуры должны обеспечивать как можно более полное покрытие сетевой активности Medusa, а не обнаруживать только один частный сценарий, отдельную команду или конкретную конфигурацию стенда.

При этом необходимо учитывать качество детектирования: сигнатуры должны быть достаточно специфичными, чтобы минимизировать ложные срабатывания на легитимный HTTP-трафик. При выборе признаков необходимо оценивать баланс между полнотой покрытия и количеством потенциальных false positive.

Исходные проекты:

- Mythic C2 — https://github.com/its-a-feature/Mythic
- Medusa Agent — https://github.com/MythicAgents/Medusa
- Mythic HTTP C2 Profile — https://github.com/MythicC2Profiles/http
- Suricata — https://suricata.io/
- Dalton — https://github.com/secureworks/dalton

Что необходимо предоставить

По результатам выполнения задания необходимо предоставить:

1. Сигнатуру или набор сигнатур Suricata.
   Сигнатуры должны быть направлены на максимально полное обнаружение исследуемого сетевого взаимодействия Medusa с Mythic C2 через HTTP C2 Profile.
2. Отчёт в любом удобном формате, из которого должна быть понятна логика исследования и разработки сигнатур.
   В отчёте необходимо отразить:
   - каким образом был развернут или воспроизведён исследуемый сценарий;
   - какую сетевую активность агента удалось получить и записать;
   - какие особенности сетевого трафика рассматривались в качестве потенциальных признаков;
   - какие признаки были отброшены и почему;
   - какие признаки вошли в итоговые сигнатуры и почему;
   - насколько полно разработанные правила покрывают исследованную сетевую активность агента;
   - какие сценарии или варианты работы агента могут остаться необнаруженными;
   - какие возможны false positive и false negative;
   - за счёт чего могут возникать ложные срабатывания на легитимный HTTP-трафик.

3. Подтверждение проверки сигнатур.
   Необходимо показать, что разработанные правила были фактически запущены на записанном трафике.
   Для проверки можно использовать:
   - Suricata — https://suricata.io/
   - Dalton — https://github.com/secureworks/dalton

   Допускается использование другой подходящей системы тестирования.
   В отчёте должны присутствовать результаты проверки, позволяющие убедиться, что разработанные сигнатуры действительно срабатывают на исследуемом трафике.
4. PCAP, содержащий сетевой трафик, использованный при разработке и проверке сигнатур.

Желательно, чтобы PCAP содержал не единичное подключение, а несколько сетевых сессий Medusa с различной активностью, достаточных для оценки того, насколько выбранные признаки характерны для агента в целом.